Monthly Intelligence Dispatch

April 2022

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly overview by Group-IB, an international company that specializes in the prevention of cyberthreats and the development of information security products. The objective of the Dispatch is to inform readers about the current cyberthreats, attacks by criminal groups, data leaks, and new malware. This report includes news of arrests and legal actions against members of hacker groups, as well as short-term forecasts and warnings that will help you take timely measures to protect yourself against cyberthreats. Group-IB's MTID is prepared for in-house use only and is not intended for wide distribution.

Key findings

- Group-IB detected two new campaigns conducted by the cybercriminal group OldGremlin.
- The Stormous group claims it hacked **Coca-Cola's** servers stealing more than 161 GB of data.
- Group-IB experts discovered more than **400,000** free publicly-accessible databases, most of which are located on servers in US, China, Germany, France, and India.
- **Block** reported a leak of **8.2** million credentials of current and former customers.
- Darknet websites belonging to the hacker group Revil that stopped its operations early this year went back online.
- Vmware specialists published an analysis of the RuRansom malware, which is exclusively used to attack Russian organizations.
- The hacker group NB65, which is related to hacktivists Anonymous, uses leaked source code of the Conti ransomware to attack Russian companies.
- According to GitHub developers, threat actors gained access to other users' repositories using stolen **Oauth** tokens.
- Advertisements for access to online services that withdrew from the Russian market, including **Spotify Premium, Netflix Premium,** and **Pornhub,** were recently published in the darknet.
- An underground platform RaidForums was closed as a result of an international operation **TOURNIQUET, Europol** reports.
- German authorities shut down Hydra Market, the largest illegal marketplace in the darknet.

Main story: OldGremlin

OldGremlin

Group-IB detected two more attacks on Russian companies carried out by the Russian language ransomware group OldGremlin. In their first mailout dated March 22, attackers carried out the theme of sanctions and full withdrawal of Visa and Mastercard from Russia. The email was written on behalf of a senior accountant of a Russian financial organization. To obtain a new bank card, a customer allegedly had to read the instructions and fill in a questionnaire. In fact, emails contained links to a malicious document stored in DropBox.

The suspicious mailout was detected by **Threat Hunting Framework (THF),** a proprietary Group-IB **Managed XDR** solution designed to protect infrastructure from APTs. One of intended victims, a Russian mining company, was promptly alerted about the impending thread.

Three days later, on March 25, Gremlins conducted another mailout. **Group-IB Threat Intelligence** analysts revealed this attack as a result of analyzing OldGremlin's network infrastructure. Later that day, experts analyzed the obtained malware code using the Group-IB **Managed XDR Threat** module, **Hunting Framework Polygon**, and examined commands used by threat actors to conduct their attacks.

First OldGremlin activities detected by Group-IB Threat Intelligence analysts date back to the spring of 2020. Even though the group consists of Russian-speaking hackers, it attacked Russian companies, including banks, industrial enterprises, and software developers, on numerous occasions. According to Group-IB, Gremlins conducted 13 malicious mailouts in two years. Most of them were carried out in 2020: OldGremlin sent 10 mailouts on behalf of a Russian steel and iron holding, Belorussian Minsk Tractor Works, and media holding RBK Group.

Last year, OldGremlin conducted only one mass mailout (in February), but it turned out to be a massive success and brought enough profits to last threat actors a whole year. This is confirmed by the fact that attackers demanded from one of its Russian victims an unprecedented ransom amount reaching about $3.1 million.

Key events: espionage, sabotage, leaks

Databases

Group-IB experts revealed about **400,000** free publicly-available databases. Most of them are stored on servers located in US, Germany, France, and India, while about **7,500** are hosted on Russian servers. If threat actors find such a database, they can steal confidential data or use it as an entry point in order to spread throughout the network.

Coca-Cola

The Stormous group claims it hacked **Coca-Cola's** servers stealing more than 161 GB of data. Threat actors posted this information on their Telegram channel. They intend to sell stolen data for 1.65 bitcoins ($63,000 at the current exchange rate). According to Bleeping Computer, hackers published data hash on their website, including compressed documents, text files with information about administrators, email addresses and passwords, and ZIP archives with payment data. Coca-Cola assured that they are investigating the incident but did not confirm the data breach.

1C

1C company fell victim to a DDoS attack. On April 21, users reported disruptions in 1C-EDO, 1C-OFD, and 1C:accounting software. The next day, the company officially confirmed the DDoS attack that resulted in some of its servers and services being unavailable or working slowly and unsteadily. The company then reported that most of its resources were already restored to normal operation.

GitHub

GitHub developers reported that threat actors gained access to other users' repositories located on the platform using stolen **Oauth** tokens. The attack was detected on April 12, by which time criminals already stole data belonging to dozens of organizations. GitHub believes that tokens were not obtained by compromising the service or some of its systems, and therefore hackers did not gain access to user accounts and credentials.

RuRansom

Vmware specialists published results of their analysis of a RuRansom malware, which is used exclusively to attack targets in Russia. In fact, RuRansom is not a ransomware but a wiper, a malware that irretrievably destroys encrypted files. This wiper is written in the .NET programming language and spreads like a worm. When executed, it calls a function IsRussia(), checks device's public IP and geolocation. If geolocation data do not contain the word Russia, a notification appears "Only Russian users can run this application", and the execution stops.

REvil

Darknet websites of the hacker group REvil, which put its activities on hold early this year, went back online. They redirect visitors to a new web page that describes terms and conditions offered to potential affiliates; partner bonuses include an improved version of the Revil software and 80% of ransom amounts. The new REvil website, currently advertised on a Russian language marketplace forum RuTOR, also contains information about two new victims, including an oil and gas company Oil India. Bleeping Computer observed that the new REvil blog and their payment websites work on different servers. The group's blog contains a cookie file called DEADBEEF, which previously was used by the TeslaCrypt gang. Whether this is an actual offer from the Revil group, a fraud orchestrated by some other gang, or a lure set by law enforcers has been a topic of discussion on many hacker forums. January this year saw REvil stopping its activities after eight members of the group were detained in Moscow.

NB65

The hacker group NB65, which is related to hacktivists Anonymous, uses leaked source code of the Conti ransomware to attack Russian companies. February this year saw Conti going through internal conflicts resulting in one of hacker group's members leaking first internal communications and later malware source codes, including the latest version of Conti ransomware. The NB65 group used the leaked code to create a ransomware of their own (published on VirusTotal.) Most of cybersecurity solutions identify this threat as Conti malware despite the code percent match of 66%.

Hive

The Hive ransomware attacks Microsoft Exchange servers that have ProxyShell vulnerabilities, as discovered by **Varonis** specialists in the course of investigating an attack against one of company's clients. Threat actors deploy backdoor malware on infected computers, steal account data and other valuable information using Mimikatz, and encrypt the files. Attackers obtained the WebShells used during these attacks from a publicly available repository and renamed them to avoid detection.

Cryptocurrency and NFT

Group-IB specialists discovered a new wave of cryptocurrency and NFT fraud. In just three days, from February 16 to February 18, they revealed **36** fraudulent online streams dedicated to profitable crypto investments. Threat actors launch YouTube streams on behalf of famous entrepreneurs, promise their viewers 200% return on investments while aiming to steal cryptocurrency or e-wallet credentials. In most cases, fraudsters use representations of Vitalik Buterin, Elon Musk, Brad Garlinghouse, Michael J. Saylor, Changpeng Zhao, and Cathie Wood. In less than the first three months of 2022, the number of domains used in the cryptocurrency fraud scheme exceeded last year's figure by three times. According to the analysis of crypto wallets, scammers gained more than $1.6 million.

Qbot and Emotet

According to Kaspersky Lab, the number of spam mailouts spreading banking Trojans Qbot and Emotet grew three-fold in just one month: from 3,000 emails in February to almost 30,000 in March. Both malwares can steal user data, collect information from corporate networks, and install ransomware. The detected mailouts target corporate users, including Russian-based organizations. Threat actors tap into work communications and talk victims into opening an attachment or downloading a document by following a link to a popular cloud storage. A malware file is often placed in an encrypted archive and a password is provided in the body of an email.

Block

In their report to the US Securities and Exchange Commission, **Block** (previously known as Square) reported a leak of 8.2 million credentials of the company's current and former customers. The incident took place on December 10, 2021, when a former staff member uploaded internal reports of **Cash App**, the service belonging to Block, after being dismissed from employment. The leaked documents contain full names of customers, numbers of their broker accounts related to their Cash App investment operations, and in some cases even values of their stock portfolios, holdings and trading activity for one trading day. According to Block, leaked reports did not contain credentials, insurance policy numbers, dates of birth, payment card and banking account data, or any other private information. The leak affected US customers only.

RuRansom

Cyble Research Labs discovered Borat, a new remote access Trojan that can be used to conduct DDoS attacks, bypass UAC, and deploy ransomware. This Trojan helps obtain full control over victim's mouse and keyboard, gain access to their files and network access points, and conceal traces of attackers' activity. Operators can choose parameters to either create minor payloads or compile them using elements that are necessary for an ongoing attack. Borat functionality includes keylogging, data encryption, DDoS attacks, recording audio and video, remote desktop control, reverse proxy, and stealing account data. Each functionality has its own dedicated module. According to Cyble, Borat's tool kit makes it a dangerous threat that brings together a RAT, a spyware, and a ransomware.

Borat

Microsoft made a statement about the eradication of the infrastructure of the Zloader botnet. The company joined forces with FS-ISAC, H-ISAC, ESET, Black Lotus Labs, Palo Alto Networks Unit 42, and Avast, disabling 65 domains used by ZLoader as C&C servers and 319 domains used to create backup communication channels. Zloader (also known as Terdot and DELoader), a well-recognized banking Trojan first detected in 2015, in recent years greatly expended its functionality. For example, it can now be used either to gain remote access (as a backdoor) or to execute additional payload. Microsoft predicts that threat actors will try to bring Zloader back online. The company says it handed over the case to law enforcement and will continue to fight the botnet together with its partners.

Octo

ThreatFabric reported that Octo, a banking Trojan found in Google Play Store, was installed more than **50,000** times. This Trojan is a modified version of the ExobotCompact malware (a lightweight version of Exobot). Despite the Exobot source code having leaked as early as 2018, the rebranding helped attract new hackers to this malware. Octo spreads using applications that masquerade as Play Store installers, screen capture utilities, and fintech apps. The ultimate goal of hackers is to automatically initiate transactions and authorize them without involving the operator, which enables them to conduct attacks on a greater scale.

Arrests and sentences

RaidForums

An underground platform RaidForums was closed down as a result of an international operation **TOURNIQUET, Europol** reported on April 12. The operation was a joint effort of law enforcement authorities of the US, the UK, Sweden, Portugal, and Romania. The US Department of Justice has already filed charges against the founder and main administrator of the forum, 21-year-old Portuguese **Diogo Santos Coelho,** known as '**Omnipotent**.' He was detained in Great Britain as early as December 31 at the request of the US authorities. Launched in 2015, RaidForums was considered a major hacker platform with a member base of more than half a million users. The forum specialized in selling data bases varying from website credentials to personal data of citizens of various countries, including full names, addresses, phone numbers, email addresses, passport and driving license photos. Group-IB suggests, however, that the arrest of Omnipotent and the closing down of his forum will give rise to an emergence of his successors. One of the most active forum members, Pompompurin, has already created an almost complete copy of RaidForums, resulting in most sellers moving to the new platform and continuing their operation there.

Hydra Market

April 5 saw German authorities shutting down Hydra Market, a Russian language underground marketplace. Law enforcers seized servers the marketplace was hosted on and confiscated 543 bitcoins (about EUR 20.2 million at the current exchange rate.) A banner announcing the official closure was posted on the platform's website. Hydra Market was the single largest underground marketplace in the darknet: in 2020 alone, its turnover amounted to EUR 1.23 billion. Hydra has been active starting from at least 2015, having around 17 million users and more than 19,000 registered merchants selling drugs, fake documents, stolen data, and digital services. The Hydra Market investigation has been under way since 2021 as a joint effort of the Federal Criminal Police Office (BKA), the Frankfurt branch of the Germany's Central Office for Combating Cybercrime (ZIT), and several US federal agencies. The US Department of Justice filed charges against Dmitry Pavlov, a Russian national accused of distribution of drugs and administering the Hydra Market's servers; he was arrested in Moscow on April 11.

Forecasts and warnings

- Due to increase in the number of cyberattacks, including those conducted for espionage or sabotage, companies must improve their defenses and use Threat Intelligence systems and dedicated solutions to protect against targeted threats. According to a research conducted by SearchInform, 95% companies (out of 900 respondents) do not go beyond basic anti-virus software, while 62% allocate budget only for license key renewal and tech support. Group-IB strongly recommends using Group-IB Threat Hunting Framework (THF) to protect infrastructure from APTs and proactively hunt for threats using threat intelligence.

- Digital transformation and migrating data to cloud infrastructures is causing an increase in the number of digital assets. Some of them end up as shadow ITs: accessible from the Internet, they are neither updated, nor controlled, nor protected by the organization. The new Group-IB External Attack Surface Management (EASM) solution uses Threat Intelligence to collect all cybersecurity risks faced by the organization, from data leaks to an open RDP ports, in one dashboard and monitor them in real time, which greatly helps cut down on time and resources spent by the IT and security teams.

- ProxyShell vulnerabilities first became known in summer 2021. They exploit Microsoft Exchange Client Access Service (CAS), which uses port 443, and help remotely execute malicious code without authenticating on Microsoft Exchange servers. Hive attacks clearly demonstrated that many companies omitted to install ProxyShell patches.

- Advertisements for access to online services that withdrew from the Russian market, including Spotify Premium, Netflix Premium, and Pornhub, were published in the darknet. Around 40% of such advertisements are created by cybercriminals who sell access to stolen accounts, which means that a buyer can lose not only their money, but their credentials as well, Kommersant reports.
  Selling accounts from services with paid access is a popular criminal business. Threat actors infest computers of their victims with stealers and collect saved user passwords. It is advisable to refrain from such purchases to avoid compromising your personal data and infesting your device with malware.

If you would like to receive more detailed information about a specific incident, threat, or criminal group, please contact us.

We conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com